

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Enterprise Risk Management: Risk Frameworks and Risk Treatment

1. Learning Objectives

- By the end of this lecture, you will be able to Define enterprise risk management (ERM) and explain how cloud security risk fits within the broader ERM discipline.
- By the end of this lecture, you will be able to Describe the core risk management cycle defined by ISO 31000 and apply its stages to a cloud risk scenario.
- By the end of this lecture, you will be able to Outline the six steps of the NIST Risk Management Framework (SP 800-37) and explain their relevance to FedRAMP authorisation.
- By the end of this lecture, you will be able to Calculate Single Loss Expectancy (SLE) and Annualised Loss Expectancy (ALE) from a given set of risk metric inputs.
- By the end of this lecture, you will be able to Compare the five risk treatment strategies — avoidance, mitigation, transfer, sharing, and acceptance — and identify the appropriate strategy for a given scenario.

2. Introduction: Risk as a Business Language

The Chief Risk Officer of a multinational insurance group sits on the company's cloud adoption steering committee. When the CISO presents a proposal to migrate the claims processing platform to the cloud, the CRO does not ask about encryption algorithms. She asks: what is the exposure? What controls reduce it? Who carries the loss if something goes wrong? And how does this risk compare to the twenty other risks on the enterprise risk register?

This is the environment in which cloud security professionals must operate. Risk is the common currency that translates technical security findings into executive decisions. Enterprise Risk Management provides the structured vocabulary and process for that translation. It ensures that a data breach in a cloud environment is not just an IT problem — it is treated as a financial, reputational, operational, and regulatory risk simultaneously, evaluated at the same governance level as credit risk, market risk, and legal liability.

This lecture covers the frameworks that structure enterprise risk management — ISO 31000, NIST SP 800-37, and COSO ERM — and the quantitative metrics that make risk comparable: AV, EF, SLE, ARO, and ALE. It then works through each risk treatment strategy, because knowing what a risk costs is only useful if you know how to act on it. These concepts appear throughout the CCSP exam and form the foundation of cloud governance decisions in every regulated industry.

3. Core Concepts Explained

3.1 Enterprise Risk Management — Definition and Scope

Definition: Enterprise Risk Management (ERM) is the organisation-wide discipline of identifying, assessing, and managing all categories of risk — strategic, financial, operational, reputational, legal, and technological — within a unified governance framework.

Business relevance: Cloud security risk does not operate in isolation. A data breach simultaneously creates regulatory exposure, reputational damage, operational disruption, and financial liability. ERM ensures that the security team's findings are visible to, and acted on by, the people who can authorise the resources to address them — including the board and C-suite.

Practitioner angle: In cloud environments, ERM is complicated by the shared responsibility model. Controls are split between customer and provider. Risk cannot be fully assessed without accounting for what the provider is responsible for, what the provider can demonstrate through audits, and what residual exposure remains with the customer organisation.

Real-world example: A global bank's ERM programme includes a cloud provider concentration risk metric: the percentage of mission-critical workloads hosted on any single cloud platform. When this metric breaches a threshold, the risk committee triggers a review — not because any specific security control has failed, but because the aggregate dependency on one provider creates systemic risk that no individual technical control can address.

3.2 ISO 31000 — International Risk Management Standard

Definition: ISO 31000 is the international standard for risk management principles and guidelines. It defines risk as 'the effect of uncertainty on objectives' and provides a framework-agnostic process for managing it.

The ISO 31000 risk management cycle: Establish context → Identify risks → Analyse risks → Evaluate risks → Treat risks, with Communication & Consultation and Monitoring & Review running continuously across all stages.

Business relevance: ISO 31000 is not prescriptive about which controls to implement. It is prescriptive about how to think about and manage risk systematically. This makes it applicable across all risk domains, including cloud security, without requiring technology-specific expertise from senior leadership.

Practitioner angle: ISO 31000's 'establish context' step is often skipped in practice. For cloud environments, this means explicitly defining scope (which cloud services are in scope?), the risk criteria the organisation uses (what level of residual risk is acceptable?), and the stakeholders who must be involved in risk decisions. Skipping this step leads to risk assessments that produce findings without actionable decisions.

Real-world example: A manufacturer adopting cloud-based IoT fleet management uses ISO 31000 to structure its risk programme, applying the same risk cycle to cybersecurity, supply chain reliability, and product liability. The unified framework means the CFO and CTO see all categories of risk in the same governance format, enabling coherent prioritisation.

3.3 NIST SP 800-37 — Risk Management Framework (RMF)

Definition: NIST Special Publication 800-37 defines the US government's Risk Management Framework (RMF), a six-step process for managing risk in information systems.

The six RMF steps: (1) Categorise — determine the impact level of the system based on confidentiality, integrity, and availability. (2) Select — choose appropriate controls from NIST SP 800-53 based on the impact category. (3) Implement — put the selected controls in place. (4) Assess — evaluate whether the controls are working correctly. (5) Authorise — obtain an authorisation decision from a senior official to operate the system. (6) Monitor — continuously track control effectiveness and respond to changes.

Business relevance: FedRAMP — the US federal programme for cloud service authorisation — is built directly on the RMF. Cloud providers seeking to offer services to US federal agencies must obtain FedRAMP authorisation, which follows the RMF steps with NIST 800-53 controls as the baseline. Understanding RMF is therefore essential for cloud professionals working in or with the US government sector.

Practitioner angle: The Authorise step in RMF is often misunderstood. It is not a rubber-stamp — it is a formal acceptance of residual risk by an Authorising Official (AO) who has read the security assessment report and the plan of action and milestones. This formal accountability is what makes the RMF credible as a governance mechanism.

Real-world example: AWS GovCloud is a FedRAMP-authorized cloud environment that has completed the RMF process for high-impact federal workloads. Federal agencies can review the associated System Security Plan and security assessment reports in the FedRAMP Marketplace, confirming that the required controls have been selected, implemented, assessed, and authorised.

3.4 COSO ERM Framework

Definition: COSO ERM (Committee of Sponsoring Organizations Enterprise Risk Management) connects risk management directly to an organisation's strategy and performance. It is widely used in the governance and financial audit domains.

Business relevance: COSO ERM situates risk management at the board level. It expects risk appetite to be explicitly defined, communicated, and linked to strategic objectives. For cloud security professionals, this means framing cloud risk in terms that boards and audit committees recognise — risk tolerance statements, risk appetite metrics, and risk-adjusted return calculations.

Practitioner angle: COSO ERM is less prescriptive about specific controls than NIST frameworks. Its value is in the governance conversation — it provides a language for

discussing cloud risk alongside strategic, financial, and operational risk without requiring technical fluency from every participant in the conversation.

3.5 Risk Quantification Metrics

Risk metrics convert qualitative risk discussions into numbers that can be compared, budgeted, and communicated to executives who do not speak security jargon.

Asset Value (AV): The monetary worth of an asset. For a cloud-hosted database containing customer records, AV encompasses the cost of re-creation, regulatory fines if data is lost, contractual penalties, and reputational damage — not just the infrastructure cost.

Exposure Factor (EF): The percentage of an asset's value that would be lost if a specific threat event occurred. A ransomware attack that encrypts all data in a cloud storage bucket but the data is fully recoverable from a recent backup might have an EF of 10% (representing recovery cost and downtime impact). A catastrophic data destruction event with no backup might have an EF of 100%.

Single Loss Expectancy (SLE) = $AV \times EF$. SLE is the expected financial loss from a single occurrence of a specific threat. If a customer data repository has an AV of \$2,000,000 and a breach scenario has an EF of 15%, the SLE is \$300,000.

Annualised Rate of Occurrence (ARO): How many times a specific threat event is expected to occur in a year. An ARO of 0.25 means once every four years. An ARO of 2.0 means twice per year on average.

Annualised Loss Expectancy (ALE) = $SLE \times ARO$. ALE is the expected annual financial impact from a specific threat. Using the above example: $SLE \text{ of } \$300,000 \times ARO \text{ of } 0.25 = ALE \text{ of } \$75,000$. If a control costs \$20,000 per year and reduces the ALE to \$30,000, the net saving is \$25,000 — the control is economically justified.

Practical limitation: These numbers depend on estimates that can be difficult to establish precisely, particularly for ARO in novel threat categories. Their value is not mathematical precision but structured thinking: they force explicit documentation of assumptions and create a basis for comparing risk treatment costs against expected losses.

Think of ALE as: an annual insurance premium calculation. If you expect to lose an average of \$75,000 per year from a specific risk category, you should be willing to spend up to that amount annually on controls that eliminate it. Spending more than the ALE on mitigation is not economically rational — unless the non-financial consequences (regulatory penalty, reputational harm, loss of licence to operate) create additional justification.

3.6 Risk Treatment Strategies

Risk Avoidance: Eliminate the activity that creates the risk. In cloud environments, avoidance might mean not storing raw payment card data in the cloud — instead tokenising at the point of capture so no sensitive data ever enters the cloud boundary. Avoidance is appropriate

when the risk exceeds the value of the activity that generates it. It is not always feasible; avoiding cloud adoption entirely to avoid cloud risk is rarely a viable business strategy.

Risk Mitigation: Implement controls to reduce the likelihood or impact of a risk. This is the dominant treatment strategy in practice. Encryption, multi-factor authentication, network segmentation, and patching are all mitigation controls. Mitigation rarely eliminates risk entirely — residual risk always remains, and that residual risk must be assessed and explicitly accepted.

Risk Transfer: Shift the financial consequences of a risk to another party. Cyber insurance is the primary mechanism. Cloud contracts that assign provider liability for specific failure modes are another form of transfer. Note: transfer does not eliminate the operational impact of an incident — it addresses the financial consequences only. Reputational harm, regulatory scrutiny, and customer loss are not fully transferable.

Risk Sharing: Distribute risk across multiple parties rather than transferring it to one. A consortium of organisations sharing a private cloud infrastructure shares both the cost of security controls and the liability for failures. A cloud contract structure that assigns different categories of liability to provider and customer depending on where the failure originated is a form of risk sharing within a bilateral relationship.

Risk Acceptance: Acknowledge a risk and choose not to treat it further — because the treatment cost exceeds the expected loss, or because residual risk falls within the organisation's defined risk tolerance. Acceptance must be documented, approved at the appropriate level (not informally decided by an individual), and reviewed periodically. Acceptance is a deliberate management decision, not a failure to act.

4. Risk Frameworks Comparison

Framework	Issuing Body	Scope	Key Strength	Relevance to Cloud
ISO 31000	ISO/IEC	Universal / any domain	Principle-based, framework-agnostic risk cycle	Applies to cloud risk within broader ERM; internationally recognised
NIST SP 800-37 (RMF)	NIST (US government)	US federal information systems; FedRAMP	Structured 6-step process; links to NIST 800-53 control catalogue	Required for FedRAMP authorisation; widely adopted in US enterprise
COSO ERM	COSO	Enterprise governance and strategy	Connects risk to organisational objectives and board-level governance	Frames cloud risk in terms boards and audit committees recognise

5. Risk Treatment Options — Decision Matrix

Treatment	Description	When to Apply	Cloud Example
Avoidance	Eliminate the risk-generating activity	Risk > value of the activity	Do not store PII in the cloud if regulatory exposure is unacceptable
Mitigation	Reduce likelihood or impact through controls	Risk is acceptable after controls; residual risk within tolerance	Implement encryption, MFA, and network segmentation
Transfer	Shift financial impact to third party	Financial loss is insurable or contractually allocable	Cyber insurance; contractual provider liability clauses
Sharing	Distribute risk across multiple parties	Risk is shared by multiple stakeholders	Multi-party cloud consortia; split liability contracts
Acceptance	Document and approve risk without further treatment	Treatment cost > expected loss; risk within tolerance	Accept low-probability, low-impact misconfiguration risk with monitoring

Incident: In 2021, a misconfiguration in an Azure Blob Storage account exposed millions of records belonging to a global consulting firm. The firm's risk programme had previously assessed storage misconfiguration as a medium-risk item and accepted residual risk after implementing role-based access controls. The incident highlighted two ERM failures: the ALE calculation had underestimated the likelihood of misconfiguration (ARO was set too low), and the acceptance decision had not been reviewed since initial cloud adoption. The case reinforced the principle that risk acceptance must be treated as a living decision with a review trigger — not a permanent closure.

6. Exam Focus

- ISO 31000 defines risk as 'the effect of uncertainty on objectives' and prescribes a cyclic process, not specific controls.
- NIST RMF has six steps: Categorise, Select, Implement, Assess, Authorise, Monitor. Know the order and what each step produces.
- FedRAMP = NIST RMF applied to US federal cloud service authorisations. Common exam linkage.
- COSO ERM connects risk to strategy and performance at the board level. Not a technical security framework.
- ALE formula: $SLE \times ARO$. SLE formula: $AV \times EF$. Expect to calculate or interpret these in a scenario question.

- Risk acceptance requires documentation and approval — it is not the same as ignoring a risk.
- Common distractor: choosing 'risk avoidance' for a scenario where the risk is inherent to the business activity. True avoidance means stopping the activity — not just adding controls.
- Common distractor: treating cyber insurance as eliminating risk. Transfer addresses financial consequences; operational and reputational impact remains.

7. Key Terms Glossary

Enterprise Risk Management (ERM): Organisation-wide discipline for identifying and managing all risk categories within a unified governance framework.

ISO 31000: International standard defining risk management principles and a cyclic risk process applicable to any domain.

NIST SP 800-37 (RMF): US government Risk Management Framework with six steps: Categorise, Select, Implement, Assess, Authorise, Monitor.

COSO ERM: Enterprise governance framework connecting risk management to strategy and board-level performance objectives.

FedRAMP: US federal programme requiring cloud service providers to obtain RMF-based authorisation before serving federal agencies.

Asset Value (AV): The monetary worth of an asset, including all tangible and intangible loss components.

Exposure Factor (EF): The percentage of an asset's value expected to be lost in a single threat event occurrence.

Single Loss Expectancy (SLE): Expected financial loss from one occurrence of a specific threat: $AV \times EF$.

Annualised Rate of Occurrence (ARO): Expected number of times a specific threat event will occur in a given year.

Annualised Loss Expectancy (ALE): Expected annual financial loss from a specific threat: $SLE \times ARO$.

Residual Risk: The risk that remains after controls have been applied; must be assessed and formally accepted.

Risk Acceptance: A documented, approved management decision to acknowledge a risk without further treatment because it falls within risk tolerance.

8. Quick Revision Checklist

- ☐ I can define ERM and explain why cloud security risk fits within its scope.

- ☐ I can describe the ISO 31000 risk management cycle and name all stages.
- ☐ I can list the six steps of the NIST RMF in order and state what each produces.
- ☐ I can explain the connection between NIST RMF and FedRAMP authorisation.
- ☐ I can calculate SLE given AV and EF, and ALE given SLE and ARO.
- ☐ I can identify which risk treatment strategy applies to a given scenario.
- ☐ I understand that risk transfer addresses financial consequences but not operational or reputational impact.
- ☐ I know that risk acceptance requires formal documentation and periodic review.
- ☐ I can distinguish between risk sharing and risk transfer.
- ☐ I understand that residual risk always exists after mitigation and must be explicitly accepted.

9. Practice Questions (10 MCQs)

Question 1 (Scenario-Based Question)

Scenario: A healthcare provider is evaluating whether to migrate its patient records management system to a cloud platform. The risk committee asks for a formal financial estimate of the expected annual loss from a ransomware attack against the cloud-hosted system. The asset is valued at \$4,000,000. Historical analysis suggests that a ransomware attack on this type of system would typically destroy or make inaccessible 60% of data before recovery mechanisms activate. The organisation expects this type of attack to occur on average once every five years. What is the Annualised Loss Expectancy (ALE)?

A) \$480,000 — Incorrect. This figure appears to multiply $AV \times EF$ without applying the ARO. $AV \$4M \times EF 60\% = SLE \$2,400,000$. Dividing by 5 (ARO 0.2) gives ALE \$480,000 — this is actually correct. Let's recalculate: $ARO = 1/5 = 0.2$. $SLE = 4,000,000 \times 0.6 = 2,400,000$. $ALE = 2,400,000 \times 0.2 = 480,000$.

B) \$2,400,000 — Incorrect. \$2,400,000 is the Single Loss Expectancy ($SLE = AV \times EF = \$4,000,000 \times 0.60$). This represents the loss from a single attack, not the annualised expectation.

C) \$240,000 — Incorrect. This may result from applying ARO incorrectly (e.g. dividing SLE by 10 rather than multiplying by 0.2). ARO of once every five years = 0.2, not 0.1.

D) \$4,000,000 — Incorrect. This is the full Asset Value — the loss if 100% of the asset were destroyed in a single event with zero recovery, every year. Neither of those conditions applies here.

Question 2 (Scenario-Based Question)

Scenario: A government defence contractor is migrating a classified research collaboration platform to a cloud service provider. The contract requires the platform to be hosted on a FedRAMP-authorised service and for the system to have a formal authorisation to operate signed by a senior government official. Which risk management framework governs this process?

A) ISO 31000 — Incorrect. ISO 31000 is an international risk management standard that defines principles and a risk cycle. It does not produce formal system authorisations or link to FedRAMP.

B) COSO ERM — Incorrect. COSO ERM is a governance framework connecting risk to strategy. It does not define a system authorisation process or underpin FedRAMP.

C) NIST SP 800-37 (RMF) — Correct. FedRAMP is built on the NIST Risk Management Framework. The six-step RMF process — Categorise, Select, Implement, Assess, Authorise, Monitor — produces the Authorisation to Operate (ATO) signed by the Authorising Official, which is the formal approval this scenario describes.

D) COBIT 5 — Incorrect. COBIT is an IT governance framework. While useful for governance alignment, it does not define the system authorisation process required for FedRAMP engagements.

Question 3 (Scenario-Based Question)

Scenario: A cloud-hosted e-commerce platform has been assessed as carrying significant risk from credential-stuffing attacks. The security team recommends implementing adaptive multi-factor authentication and bot detection controls at a combined annual cost of \$85,000. The risk team calculates the current ALE for credential-stuffing at \$210,000 and estimates the controls will reduce ALE to \$55,000. Should the controls be implemented based on quantitative risk analysis?

A) No, because the cost of controls exceeds the residual ALE. — Incorrect. The decision metric compares control cost to the reduction in ALE, not the residual ALE. The reduction is $\$210,000 - \$55,000 = \$155,000$. The control costs \$85,000. Net benefit = \$70,000.

B) Yes, because the reduction in ALE (\$155,000) exceeds the annual control cost (\$85,000), producing a net benefit of \$70,000. — Correct. Quantitative risk analysis justifies a control when the expected loss reduction exceeds the cost. Here, the ALE reduction of \$155,000 against a control cost of \$85,000 produces a net positive return of \$70,000, making implementation economically defensible.

C) No, because risk transfer through cyber insurance is always preferable to risk mitigation. — Incorrect. There is no absolute rule preferring transfer over mitigation. The economically optimal treatment depends on the specific cost-benefit calculation for each option.

D) Yes, because implementing security controls always reduces total risk to an acceptable level. — Incorrect. Controls reduce risk — they do not guarantee reduction to any particular level. The decision must be grounded in cost-benefit analysis, not an absolute assertion about control effectiveness.

Question 4 (Knowledge Question)

ISO 31000 defines risk as which of the following?

A) The probability that a threat will exploit a vulnerability multiplied by the resulting impact. — Incorrect. This is a commonly used security definition of risk but not ISO 31000's definition. ISO 31000 takes a broader view that applies across all risk domains.

B) The effect of uncertainty on objectives. — Correct. ISO 31000's definition of risk as 'the effect of uncertainty on objectives' is framework-agnostic and applies to any type of risk across any organisation. This definition is worth memorising exactly for the CCSP exam.

C) A negative event that may occur with some probability and has a defined financial impact. — Incorrect. This is a colloquial definition. ISO 31000 explicitly notes that risk can have positive effects (upside risk / opportunity) as well as negative ones. The definition focuses on uncertainty, not solely on negative outcomes.

D) A potential threat to the confidentiality, integrity, or availability of an information asset. — Incorrect. This is an information security definition aligned with the CIA triad. ISO 31000 is not limited to information security risk.

Question 5 (Knowledge Question)

What is the correct sequence of steps in the NIST Risk Management Framework (SP 800-37)?

A) Identify → Protect → Detect → Respond → Recover — Incorrect. These are the five functions of the NIST Cybersecurity Framework (CSF), not the six steps of the NIST RMF (SP 800-37).

B) Categorise → Select → Implement → Assess → Authorise → Monitor — Correct. The NIST RMF's six steps begin with system categorisation based on impact level, followed by control selection from SP 800-53, implementation, assessment, formal authorisation, and ongoing monitoring.

C) Establish context → Identify → Analyse → Evaluate → Treat → Monitor — Incorrect. This is the ISO 31000 risk management cycle, not the NIST RMF.

D) Plan → Do → Check → Act — Incorrect. Plan-Do-Check-Act is the Deming cycle used in ISO management system standards (including ISO 27001). It is not the NIST RMF.

Question 6 (Knowledge Question)

A cloud provider's contract contains a clause limiting the provider's liability for data loss to a maximum of three months' subscription fees. Which risk treatment strategy does this clause primarily represent from the customer's perspective?

A) Risk avoidance — Incorrect. Risk avoidance means the customer would eliminate the activity generating the risk — i.e., not use the cloud service at all. A liability cap clause means the service is still being used.

B) Risk mitigation — Incorrect. Risk mitigation involves reducing the likelihood or impact through controls. A contractual liability cap does not reduce the probability of a loss event or its operational impact — it limits only the financial recovery the customer can claim.

C) Risk acceptance — Incorrect. The customer may ultimately need to accept the residual financial risk above the cap, but the liability cap clause itself is a contractual mechanism for allocating financial exposure — which is transfer, not acceptance.

D) Risk transfer (partial) — Correct. The liability cap clause transfers some financial exposure to the provider — but only up to three months of fees. Risk above that cap remains with the customer. This is partial transfer. The customer should assess whether that cap is sufficient or whether supplemental insurance or contract negotiation is warranted.

Question 7 (Knowledge Question)

An organisation's risk assessment identifies a low-probability, low-impact configuration drift risk in its cloud environment. Implementing the recommended control would cost more than the calculated ALE. The risk committee formally documents its position and assigns a review date twelve months out. Which risk treatment has been applied?

A) Risk avoidance — Incorrect. The organisation has not eliminated the activity generating the risk. The cloud environment and associated configuration drift risk remain.

B) Risk mitigation — Incorrect. No control has been implemented to reduce the likelihood or impact. The decision is to leave the risk unmitigated.

C) Risk acceptance — Correct. Risk acceptance means formally acknowledging a risk and deciding not to treat it further — because the treatment cost exceeds the expected loss or because the risk falls within the defined risk tolerance. The formal documentation and review date described are the hallmarks of proper risk acceptance.

D) Risk transfer — Incorrect. No financial consequences have been shifted to another party. The organisation retains full exposure.

Question 8 (Knowledge Question)

Which risk framework is most closely associated with board-level strategy and performance governance, and is widely used in the financial audit community?

A) NIST SP 800-37 — Incorrect. NIST SP 800-37 is the US government's Risk Management Framework for information systems authorisation. It is not primarily a board-level governance framework.

B) ISO 31000 — Incorrect. ISO 31000 provides universal risk management principles applicable at any level. It is not specifically associated with board-level strategy linkage in the financial audit community.

C) COSO ERM — Correct. COSO ERM was developed by the Committee of Sponsoring Organizations — which includes the AICPA and major financial governance bodies — and is specifically designed to connect risk management to strategy and performance at the board and executive level. It is the framework most familiar to financial auditors and corporate governance professionals.

D) COBIT 2019 — Incorrect. COBIT is an IT governance framework, not a general enterprise risk management standard. While it addresses risk, it does not have the board-level strategy and financial audit heritage of COSO ERM.

Question 9 (Knowledge Question)

The Exposure Factor for a specific threat scenario is assessed at 25%. The Asset Value is \$800,000. What is the Single Loss Expectancy?

A) \$25,000 — Incorrect. This appears to treat EF as a dollar figure rather than a percentage applied to AV. $SLE = AV \times EF = \$800,000 \times 0.25 = \$200,000$.

B) \$200,000 — Correct. $SLE = AV \times EF$. $\$800,000 \times 0.25 = \$200,000$. This represents the expected financial loss from a single occurrence of the threat.

C) \$600,000 — Incorrect. This subtracts EF from AV as if EF were a fixed dollar amount ($\$800,000 - \$200,000$). EF is a percentage of AV applied as a multiplier in the SLE formula.

D) \$32,000,000 — Incorrect. This appears to multiply AV by EF without converting the percentage, or applies an incorrect formula. The correct SLE is $\$800,000 \times 0.25 = \$200,000$.

Question 10 (Knowledge Question)

Which statement most accurately describes the concept of residual risk in a cloud risk programme?

A) Residual risk is eliminated once all recommended controls are implemented. — Incorrect. Controls reduce risk but do not eliminate it. Some exposure always remains — equipment can fail, controls can be misconfigured, and new threats emerge. Residual risk is inherent to any real-world security programme.

B) Residual risk is the risk that remains after controls have been applied and must be formally accepted. — Correct. After mitigation controls are in place, the remaining exposure is residual risk. This residual must be assessed against risk tolerance and formally accepted by an authorised decision-maker, not silently carried forward.

C) Residual risk exists only when no controls have been implemented. — Incorrect. Without any controls, the risk is the full inherent risk, not residual risk. Residual risk is specifically the risk remaining after controls are in place.

D) Residual risk is transferred to the cloud provider when a service level agreement is signed. — Incorrect. Signing an SLA transfers some performance-related financial exposure to the provider. It does not transfer residual security risk — the customer retains responsibility for controls within their own scope under the shared responsibility model.